

07_StaticCodeAnalysis LAB ACTIVITY

Analysis of vulnerable repositories with SAST and SCA tools



Repositories:

- <https://github.com/jellyfin/jellyfin>
- <https://github.com/pagopa/io-app>

Tools:

- SonarQubeCloud
- Trivy v0.68.2



Jellyfin

Jellyfin – Vulnerable Target

- **Version Analyzed:** Fork of version 10.9.6
- **About:** volunteer-built media solution, streaming to any device from your own server
- **Listed in:** [NVD - CVE-2025-32012](#)



PausJure / jellyfin_CyberLAB

New

Public

Last analysis: 28/01/2026, 17:29 • 139k Lines of Code • C#, JSON, ...

E

41

Security

E

76

Reliability

A

1.6k

Maintainability

E

0.0%

Hotspots Reviewed



3.5%

Duplications

- **Security Grade E** - critical vulnerabilities are present
- **Reliability Grade E** - suggesting the application is prone to unexpected behaviour
- **Maintainability Grade A** - code structure is clean
- Almost all security issues due to **CWE-20: Improper Input Validation**

arQube

My Projects

My Issues

Explore

Upgrade

🔍

🔔

LAB

PausJure / jellyfin_CyberLAB / Issues

Issues

🔗 master

— ⓘ

Filters

Clear All Filters

Software quality

1 ✕

Security41

Reliability76

Maintainability1.6k

Add to selectionCtrl + click

Severity ⓘ

Blocker13

High6

Medium20

Low2

Info0

> Code attribute

> Type

> Type Severity ⓘ

Emby.Server.Implementations/IO/ManagedFileSystem.cs

☐

Change this code to not construct the path from user-controlled data.

Intentional

Security

Blocker

Open

Not assigned

L560 • 30min effort • 4 years ago • 🔒 Vulnerability • ⚙️ Blocker

☐

Change this code to not construct the path from user-controlled data.

Responsibility

Security

Medium

Open

Not assigned

L560 • 30min effort • 4 years ago • 🔒 Vulnerability • ⚙️ Medium

☐

Change this code to not construct the path from user-controlled data.

Intentional

Security

Blocker

Open

Not assigned

L563 • 30min effort • 4 years ago • 🔒 Vulnerability • ⚙️ Blocker

☐

Change this code to not construct the path from user-controlled data.

Responsibility

Security

Medium

Open

Not assigned

L563 • 30min effort • 4 years ago • 🔒 Vulnerability • ⚙️ Medium

☐

Change this code to not construct the path from user-controlled data.

Intentional

Security

Blocker

Open

Not assigned

L585 • 30min effort • 6 years ago • 🔒 Vulnerability • ⚙️ Blocker

Report Summary

Target	Type	vulnerabilities	Secrets
Directory.Packages.props	packages-props	2	-

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

Directory.Packages.props (packages-props)
Total: 2 (UNKNOWN: 0, LOW: 0, MEDIUM: 0, HIGH: 2, CRITICAL: 0)

Library	vulnerability	Severity	Status	Installed version	Fixed version	Title
Microsoft.Extensions.Caching.Memory	CVE-2024-43483	HIGH	fixed	8.0.0	8.0.1, 9.0.0-rc.2.24473.5, 6.0.2	dotnet: Multiple .NET components susceptible to hash flooding https://avd.aquasec.com/nvd/cve-2024-43483
System.Text.Json	CVE-2024-43485			8.0.4	8.0.5, 6.0.10	dotnet: Denial of Service in System.Text.Json https://avd.aquasec.com/nvd/cve-2024-43485

Trivy Report summary

- detected 2 "High" severity vulnerabilities
- Trivy provides the exact fixed version



PausJure / io-app_CyberLAB

New

Public

Last analysis: 28/01/2026, 17:50 • 314k Lines of Code • TypeScript, JSON, ...



4

Security



406

Reliability



3.2k

Maintainability



0.0%

Hotspots Reviewed



4.7%

Duplications

IO app – „Clean” Target

- **Security Grade E:** Surprisingly, but only 4 security issues
- High number of reliability bugs
- Maintainability Grade A

Issues master

Filters Clear All Filters

Software quality

Security 2

Reliability 0

Maintainability 3

Severity 1 X

Blocker 5

High 872

Medium 1k

Low 1.4k

Info 117

Add to selection Ctrl + click

Code attribute

Type

Type Severity

Status

Security Category

Creation Date

SELECT ISSUES FOR BATCH ACTIONS

Change Select issues Navigate to issue 5 Issues 2h 14min effort

.github/workflows/pr-title-conventional-commit-linter.yml

Change this workflow to not use user-controlled data directly in a run block. Intentionality

Security Blocker cwe +

Open Not assigned L95 1h effort 1 year ago Vulnerability Blocker

.github/workflows/pr-title-linter-and-linker.yml

Change this workflow to not use user-controlled data directly in a run block. Intentionality

Security Blocker cwe +

Open Not assigned L82 1h effort 1 year ago Vulnerability Blocker

scripts/canary/replaceCanaryVersion.js

Rename "package" identifier to prevent potential conflicts with future evolutions of the JavaScript language. Consistency

Maintainability Blocker lock-in pitfall +

Open Not assigned L20 5min effort 1 year ago Code Smell Blocker

scripts/changelog/prepare_to_new_cycle.js

Rename "package" identifier to prevent potential conflicts with future evolutions of the JavaScript language. Consistency

Maintainability Blocker lock-in pitfall +

Open Not assigned L13 5min effort 5 years ago Code Smell Blocker

ts/.../login/cie/screens/CieConsentDataUsageScreen.tsx

Refactor this function to not always return the same value. Intentionality

Maintainability Blocker No tags +

Open Not assigned L67 4min effort 1 year ago Code Smell Blocker

- critical issues mostly located in GitHub workflow files, not in app source code
- This would affect the **build pipeline**

Report Summary

Target	Type	Vulnerabilities	Secrets
Gemfile.lock	bundler	2	-
ios/Podfile.lock	cocoapods	0	-
scripts/check_cie_button_exists/Pipfile.lock	pipenv	9	-
scripts/check_urls/Pipfile.lock	pipenv	25	-
yarn.lock	yarn	69	-
ts/features/itwallet/__mocks__/L3/dcL3.json	text	-	2
ts/features/itwallet/__mocks__/L3/edL3.json	text	-	1
ts/features/itwallet/__mocks__/L3/eeL3.json	text	-	1
ts/features/itwallet/__mocks__/L3/mdL3.json	text	-	2
ts/features/itwallet/__mocks__/L3/resL3.json	text	-	1
ts/features/itwallet/__mocks__/L3/tsL3.json	text	-	2

Legend:

- '-': Not scanned
- '0': Clean (no security findings detected)

Trivy Report summary

- dependency scan found many issues
- Trivy flagged potential secrets (api keys/tokens) in JSON files
- But secrets found in a __mocks__ directory, indicating likely test data

Conclusion

- SonarCloud flagged both repos as Grade E but the risks were different
- Well maintained projects can have critical security vulnerabilities or outdated dependencies
 - **False Positives:** Automated tools lack context